Laboratorio de Programación Segura I

INACAP La Serena

Informe de Desarrollo Seguro y Auditoría Técnica

Aplicación **PNK Security** — carta digital de restaurantes (PHP / MySQL)

ISO/IEC 27001:2022 | ISO/IEC 27034 | OWASP ASVS v5.0.0 | Ley 19.628 | Ley 21.719

Alumno	Martín Díaz	**Fecha**	19-10-2026
Versión revisada	v1 (entregada)	**Versión corregida**	v2 (este paquete)
Metodología	Revisión manual de código + SAST por patrones + SCA + pruebas automatizadas + pentest de laboratorio (localhost)		

Documento confidencial de carácter académico. Las pruebas activas se realizaron exclusivamente en un entorno local y aislado con datos sintéticos, conforme a las reglas de autorización y alcance (OWASP / buenas prácticas de pentesting).

1. Resumen ejecutivo

La versión original (v1) de PNK Security **no es apta para producción**: contiene dos vulnerabilidades **críticas** de inyección SQL. Una permite **iniciar sesión como administrador sin conocer la contraseña** y otra permite **leer toda la base de datos sin autenticarse**, incluidas las contraseñas, que se guardaban **en texto plano**. Se suman XSS almacenado y reflejado, ausencia de protección CSRF, conexión a la base de datos como `root` sin contraseña escrita en el código, y librerías con vulnerabilidades conocidas.

Se corrigieron **17 hallazgos** en la versión v2. Las correcciones se verificaron con **24 pruebas automatizadas (24/24 aprobadas)** y con un **pentest de laboratorio** que confirma, caso a caso, que cada ataque que funcionaba en la v1 queda bloqueado en la v2 (sección 4).

2	5	7	3	17/17	+MFA +TLS
Críticas	Altas	Medias	Bajas	Corregidas	Mejoras

> **Decisión requerida.** La v2 queda apta para un ambiente de laboratorio/QA. Para exponerla a Internet faltan controles de infraestructura que no dependen del código: TLS/HTTPS, gestor de secretos y MFA para cuentas administrativas (excepciones EXC-01 a EXC-03). Varios de esos pendientes ya se implementaron en esta versión (MFA, HTTPS con cookie Secure+HSTS, pipeline CI); sólo resta emitir el certificado del dominio real en producción. Ver sección 6 y el Anexo A.

2. Alcance y metodología

Se analizó el código y la base de datos entregados. El pentest se ejecutó en un **entorno local aislado**: dos instancias (v1 original y v2 corregida) sobre `127.0.0.1` contra un servidor compatible con MySQL 8.0, con datos sintéticos. **No** se realizaron pruebas activas contra servidores, dominios ni bases de datos reales. Las pruebas son no destructivas: demuestran cada vulnerabilidad sin extraer ni modificar datos.

Fase	Actividad	Resultado
Revisión de código	7 archivos PHP, 2 JS, 1 SQL	17 hallazgos
SAST (patrones)	Antes vs. después	51 → 1 coincidencias
SCA + integridad	Verificación de hashes SHA-256/384	jQuery y Bootstrap actualizados
Pruebas automatizadas	24 casos de seguridad	**24/24 aprobadas**
Pentest de laboratorio	7 casos v1 vs v2	**Ataques bloqueados en v2**

3. Hallazgos principales

ID	Hallazgo	Sev.	Estado v2	ISO 27001 · ASVS v5.0.0
PNK-01	SQLi en el login (bypass de autenticación)	Crítica	**Corregido**	A.8.28 · 1.2.4
PNK-02	SQLi en parámetros públicos (id, iditems...)	Crítica	**Corregido**	A.8.28 · 1.2.4, 2.2.1
PNK-03	Contraseñas en texto plano y cuentas por defecto	Alta	**Corregido**	A.5.17 · 11.4.2, 6.3.2
PNK-04	Credenciales root sin clave en el código	Alta	**Corregido**	A.8.24 · 13.2.3, 13.3.1
PNK-05	XSS almacenado en comentarios	Alta	**Corregido**	A.8.28 · 1.2.1, 3.2.2

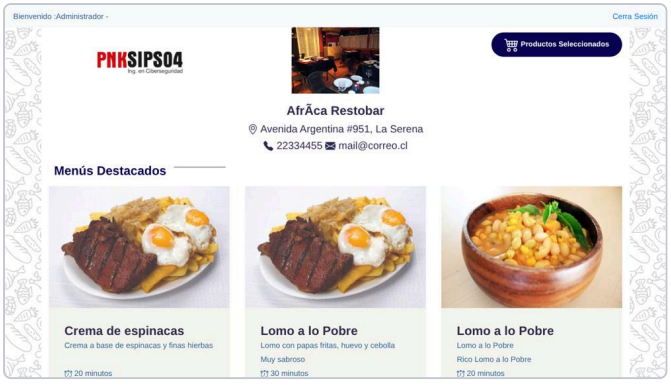
PNK-06	Control de acceso roto en comentarios	Alta	Corregido	A.5.15 · 8.2.1, 8.2.2
PNK-07	Ausencia de protección CSRF	Media	Corregido	A.8.28 · 3.5.1
PNK-08	Gestión de sesión deficiente (fijación)	Media	Corregido	A.8.5 · 7.2.4, 3.3.4
PNK-09	Login sin controles anti-fuerza bruta	Media	Corregido	A.8.5 · 6.3.1
PNK-12	XSS reflejado en id / keyid	Alta	Corregido	A.8.28 · 1.2.1
PNK-13	Librerías con CVE conocidos	Media	Corregido	A.8.8 · 15.2.1
PNK-14	Sin cabeceras de seguridad / HTTPS	Media	Corregido*	A.8.20 · 3.4.x

Listado completo (PNK-01 a PNK-17 y PRIV-01 a PRIV-05) con código vulnerable, corregido y mapeos en `docs/01_Informe_Auditoria.md` y `docs/06_Privacidad_Ley19628_21719.md`.

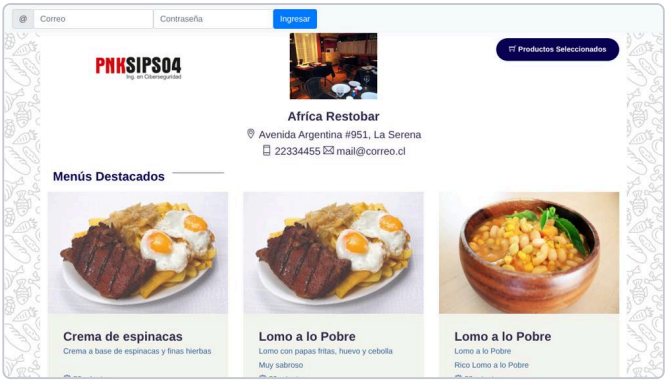
4. Evidencia del pentest: antes (v1) vs. después (v2)

4.1 PNK-01 — Bypass de autenticación por SQL Injection

En la v1, el usuario `' OR '1'='1' --` con cualquier contraseña inicia sesión como **Administrador**. En la v2 se usa consulta preparada y `password_verify()`: la credencial es rechazada con un mensaje genérico.



v1: autenticado como Administrador sin contraseña (VULNERABLE)



v2: credencial rechazada, el formulario de login permanece

4.2 PNK-12 — XSS reflejado

En la v1, `mostrar_carrito.php?keyid=…` refleja el parámetro sin escapar y ejecuta el script inyectado (banner rojo). En la v2 el parámetro se valida como entero y la página responde 404.



v1: script inyectado ejecutado (banner rojo)

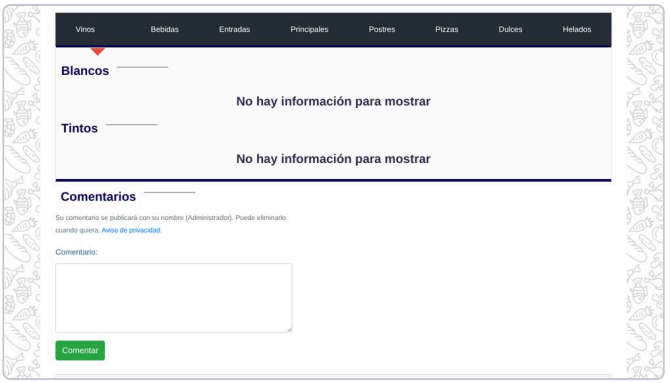
v2: 404, el parámetro no se refleja

4.3 PNK-05 — XSS almacenado

En la v1, un comentario con `<script>` se ejecuta en el navegador de cada visitante. En la v2 el comentario se almacena y se muestra como **texto escapado**, y la CSP `script-src 'self'` actúa como segunda barrera.



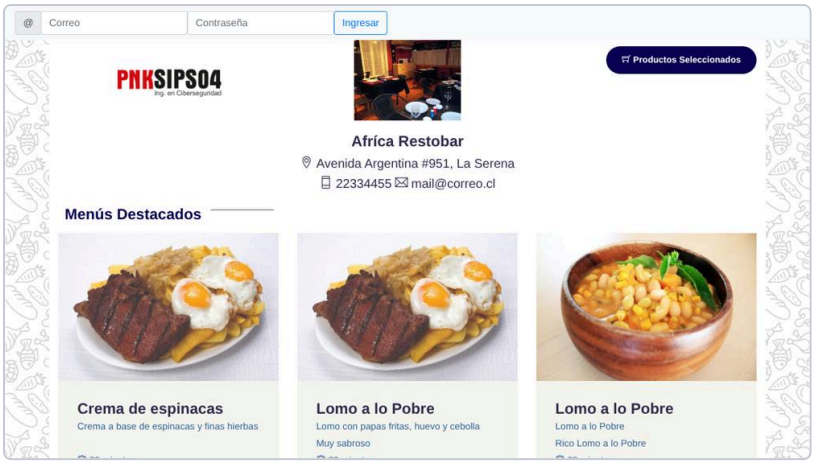
v1: el comentario malicioso ejecuta código (banner rojo)



v2: el comentario se almacena escapado; no se ejecuta

4.4 PNK-09 — Bloqueo por fuerza bruta (v2)

Tras 5 intentos fallidos, el 6º intento con la **contraseña correcta** no autentica: la cuenta queda bloqueada 15 minutos. El formulario de login permanece visible.



v2: bloqueo activo pese a la clave correcta

4.5 Evidencia adicional (HTTP)

Caso	v1 (original)	v2 (corregida)
SQLi booleana `id=1 AND 1=1` vs `1=2`	**40.105 vs 7.131 bytes (inyectable)**	**HTTP 404 en ambos**
POST a comentarios sin token CSRF	**aceptado / HTTP 500**	**HTTP 403**
Cabeceras de seguridad	**sin CSP; expone X-Powered-By**	**CSP, nosniff, Referrer-Policy, COOP, X-Frame-Options**

Registro completo en `docs/evidencia_pentest/pentest_http.txt`. El procedimiento reproducible está en `docs/13_Pentest_Laboratorio.md`.

5. Cumplimiento y privacidad

La matriz de 45 requisitos (`docs/02_Matriz_Cumplimiento.md`) mapea cada control a Ley 19.628 / 21.719, ISO 27001, ISO 27034 (ASC) y ASVS v5.0.0: **23 CUMPLE**, 13 CUMPLE PARCIAL, 2 NO CUMPLE y 5 NO VERIFICADO. Como el análisis es anterior al 01-12-2026, se aplica la **Ley 19.628 vigente** y la **Ley 21.719 como adecuación** (readiness). No se identifican datos sensibles por diseño; se agregó aviso de privacidad, seudonimización de registros, retención y supresión de comentarios por el titular.

6. Estado y pendientes

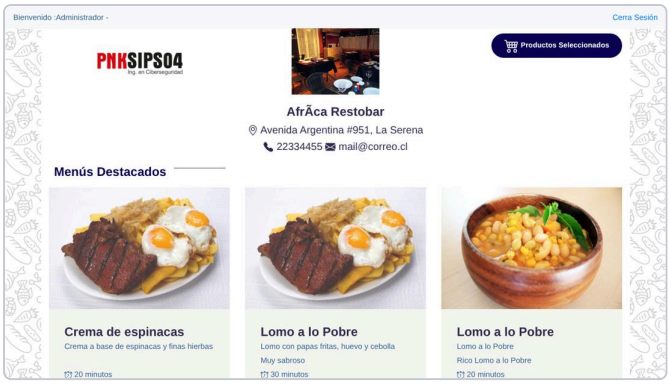
Ámbito	Estado
17 hallazgos de código	**Corregidos y verificados (27 pruebas)**
MFA / segundo factor TOTP (EXC-03)	**Implementado y probado (T25-T27)**
HTTPS: cookie Secure + HSTS (EXC-01)	**Implementado y demostrado en lab***
Pipeline CI con SAST + pruebas (ACC-05)	**Agregado (.github/workflows)**
Gestor de secretos (EXC-02)	Mitigado (vault opcional)
Certificado TLS del dominio real (ACC-01)	**Pendiente (certbot en producción)**
DAST / escaneo dinámico (ACC-02)	**Ejecutado en lab (v2: 0 críticas/altas)**
Logs centralizados / SIEM (ACC-03)	**Pendiente (infraestructura)**
Datos del responsable en el aviso de privacidad	**A cargo del responsable**

Este informe cubre el código entregado y las pruebas descritas; no garantiza la ausencia de vulnerabilidades. Los identificadores ASVS se citan contra el texto oficial de OWASP ASVS v5.0.0. El paquete incluye además 13 documentos de detalle (informe completo, matrices, ANF, catálogo ASC, threat model, privacidad, gates, plan de remediación, checklists y plan de pruebas), el código corregido, las pruebas y el SBOM.

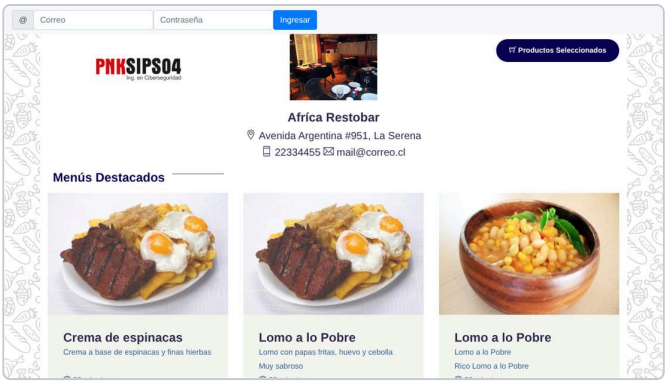
Anexo A · Evidencia por vulnerabilidad

Una evidencia por hallazgo, capturada en el laboratorio aislado (v1 original vs. v2 corregida). Las capturas de navegador muestran el ataque; los paneles de consola muestran la base de datos, el código o la respuesta HTTP.

PNK-01 · SQLi en el login (bypass de autenticación) — Crítica

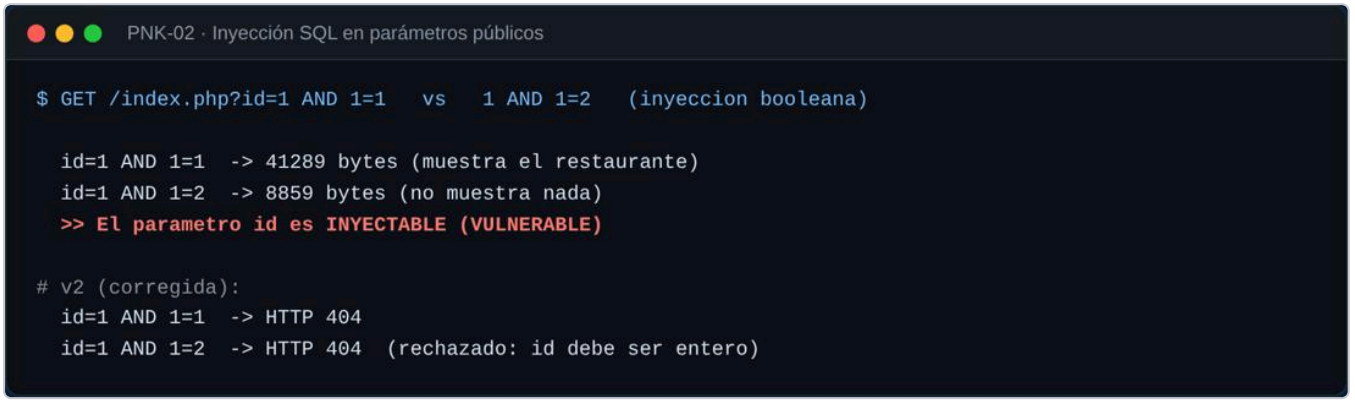


v1: entra como Administrador sin contraseña



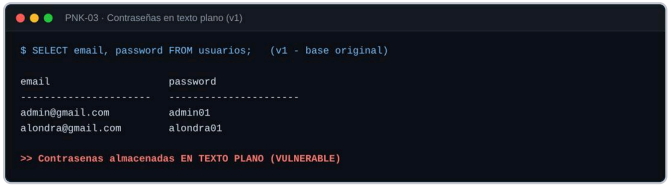
v2: credencial rechazada

PNK-02 · SQLi en parámetros públicos — Crítica



La inyección booleana cambia la respuesta en v1; en v2 el id se valida y da 404

PNK-03 · Contraseñas en texto plano — Alta



v1: contraseñas legibles en la base



v2: hash bcrypt

PNK-04 · Credenciales root en el código — Alta

PNK-04 · Credenciales root en el código

```
# v1 - setup/setup.php linea 5 (codigo ORIGINAL entregado):
     $con=mysqli_connect("localhost","root","","pnk_security");
  >> Usuario root, sin contrasena, escrito en el codigo (VULNERABLE)

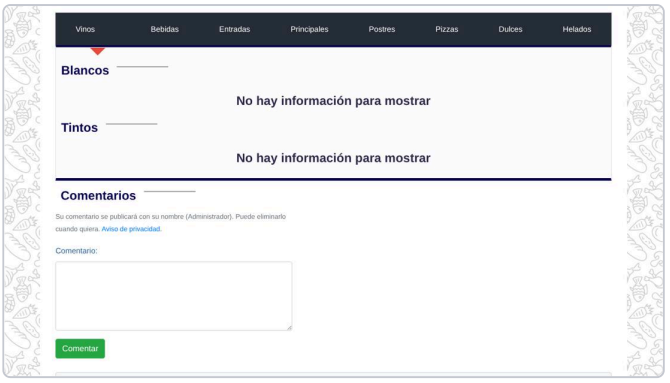
# v2 - conectar() rechaza root / clave vacia:
  RECHAZADO: Configuración de BD insegura: defina DB_USER (no root) y DB_PASS.
  >> Las credenciales viven fuera del codigo, en variables de entorno (CORREGIDO)
```

v1 conecta como root sin clave desde el código; v2 lo rechaza

PNK-05 · XSS almacenado — Alta



v1: el comentario ejecuta código



v2: se muestra escapado

PNK-06 / PNK-07 · Control de acceso y CSRF en comentarios — Alta / Media

PNK-06 / PNK-07 · Control de acceso y CSRF en comentarios

```
$ curl -X POST .../grcomentarios.php   (sin iniciar sesion, sin token CSRF)

  v2 -> HTTP 403   (403 = rechazado: exige sesion + CSRF)
  v1 -> HTTP 302   (v1 no valida sesion ni token)
```

v2 exige sesión y token (403); v1 acepta la petición

PNK-08 · Gestión de sesión — Media

PNK-08 · Cookie de sesión (HttpOnly / SameSite)

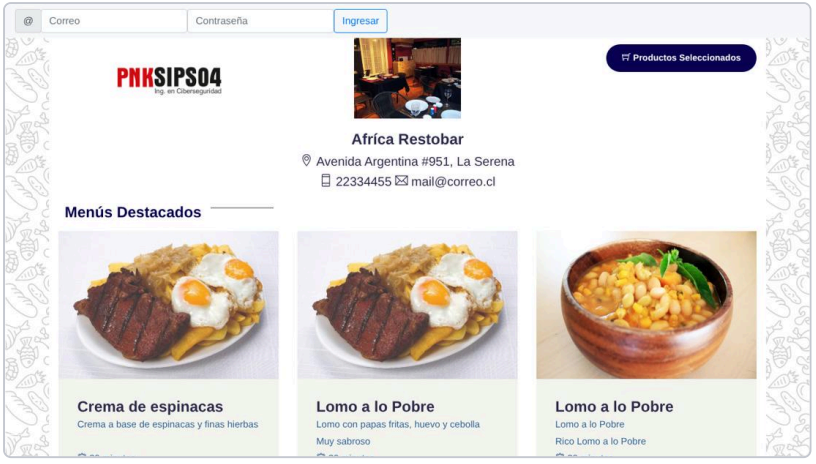
```
$ Cabecera Set-Cookie de la sesion

# v1:
  Set-Cookie: PHPSESSID=tuo8rnj94ijrjif2ufp3nbp6fe; path=/
  >> Sin HttpOnly, sin SameSite (VULNERABLE)

# v2:
  Set-Cookie: PNKSESSID=9tmnlncavh0mp5lubhnke898gd; path=/; HttpOnly; SameSite=Lax
  >> HttpOnly + SameSite=Lax (CORREGIDO)
```

v1 emite la cookie sin HttpOnly/SameSite; v2 la protege

PNK-09 · Fuerza bruta — Media



v2: tras 5 fallos la cuenta queda bloqueada aun con la clave correcta

PNK-10 · Cuentas inactivas — Media

PNK-10 · Cuentas inactivas no autentican

```
$ Login de un usuario con estado=0 (cuenta inactiva), con la clave correcta

  -> NO autenticado: la consulta exige estado=1 (CORREGIDO)
```

v2: un usuario con estado=0 no autentica aunque la clave sea correcta

PNK-11 · Lógica del carrito — Baja

PNK-11 · Lógica del carrito (vaciar ≠ cerrar sesión)

```
# v1 - carrito.php: "eliminar todo" ejecuta session_destroy()
  33:function eliminartodo()
  35:    session_destroy();
  >> Vaciar el carrito CIERRA la sesion del usuario (VULNERABLE)

# v2 - carrito.php: solo vacia el arreglo del carrito
  28:    $_SESSION['carrito'] = [];
  65:        $_SESSION['carrito'] = [];
  >> La sesion se mantiene (CORREGIDO)
```

v1: vaciar el carrito ejecutaba session_destroy(); v2 solo vacía el carrito

PNK-12 · XSS reflejado — Alta



v1: el parámetro keyid ejecuta el script

v2: 404, no se refleja

PNK-13 · Librerías con CVE conocidos — Media

PNK-13 · Librerías de terceros con CVE

```
$ Versiones de librerias frontend

v1 (original):
  jQuery v3.2.1
  Bootstrap v4.1.3
  >> jQuery 3.2.1: CVE-2019-11358, CVE-2020-11022/11023
  >> Bootstrap 4.1.3: CVE-2019-8331

v2 (corregida):
  jQuery v3.7.1
  Bootstrap v4.6.2
  >> Versiones sin CVE conocidos, verificadas por hash SHA
```

v1 usa jQuery 3.2.1 y Bootstrap 4.1.3 (con CVE); v2 los actualiza

PNK-14 · Cabeceras de seguridad — Media

PNK-14 · Cabeceras de seguridad

```
$ Cabeceras de seguridad en la respuesta HTTP

# v1:
  X-Powered-By: PHP/8.3.6
  (solo expone X-Powered-By; sin CSP ni nosniff)  >> VULNERABLE

# v2:
  Content-Security-Policy: default-src 'self'; script-src 'self'; styl...
  X-Content-Type-Options: nosniff
  Referrer-Policy: strict-origin-when-cross-origin
  Cross-Origin-Opener-Policy: same-origin
  X-Frame-Options: DENY
  >> CSP, nosniff, Referrer-Policy, COOP, X-Frame-Options (CORREGIDO)
```

v1 no envía cabeceras de seguridad; v2 agrega CSP y las demás

PNK-15 · Registro de seguridad — Media

PNK-15 · Registro de eventos de seguridad

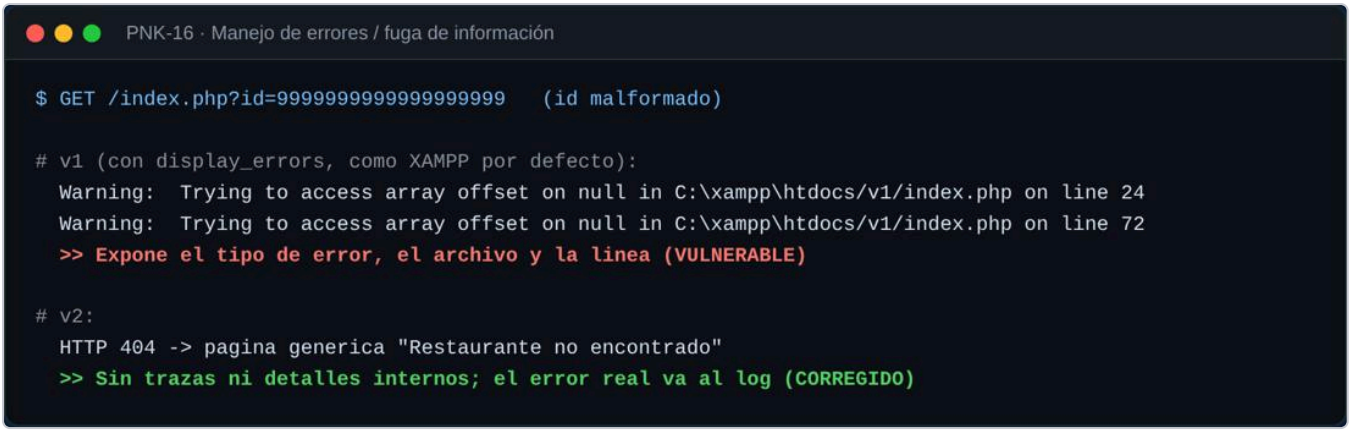
```
$ tail logs/security.log   (registro de seguridad en JSON, hora UTC)

  {"ts":"2026-10-
19T13:58:24Z","evento":"validacion_fallida","ip":"127.0.0.1","ruta":"\/index.php","usuario":null,"datos
  {"ts":"2026-10-
19T13:58:24Z","evento":"csrf_invalido","ip":"127.0.0.1","ruta":"\/grcomentarios.php","usuario":null,"da
  {"ts":"2026-10-
19T13:58:25Z","evento":"login_fallido","ip":"127.0.0.1","ruta":"\/setup\/procesalogin.php","usuario":nu
  {"ts":"2026-10-
19T13:58:56Z","evento":"validacion_fallida","ip":"127.0.0.1","ruta":"\/index.php","usuario":null,"datos

  >> Eventos con quien/que/cuando, correo seudonimizado, sin contrasenas (CORREGIDO)
  >> v1 no tenia ningun registro de seguridad
```

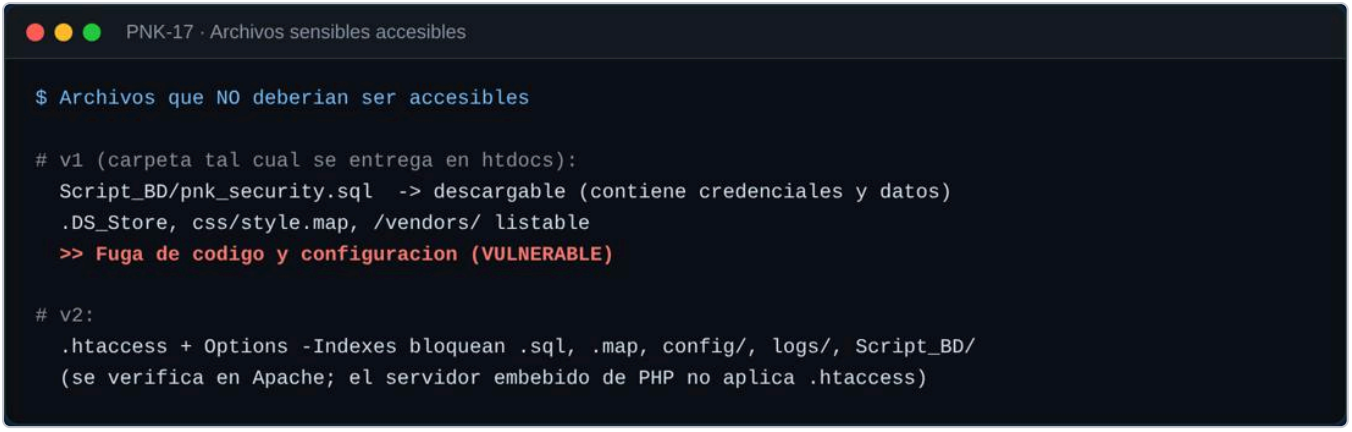
v2 registra los eventos en JSON con hora UTC y correo seudonimizado; v1 no registraba nada

PNK-16 · Manejo de errores — Baja



v1 muestra avisos con rutas internas; v2 responde una página genérica

PNK-17 · Archivos sensibles accesibles — Baja



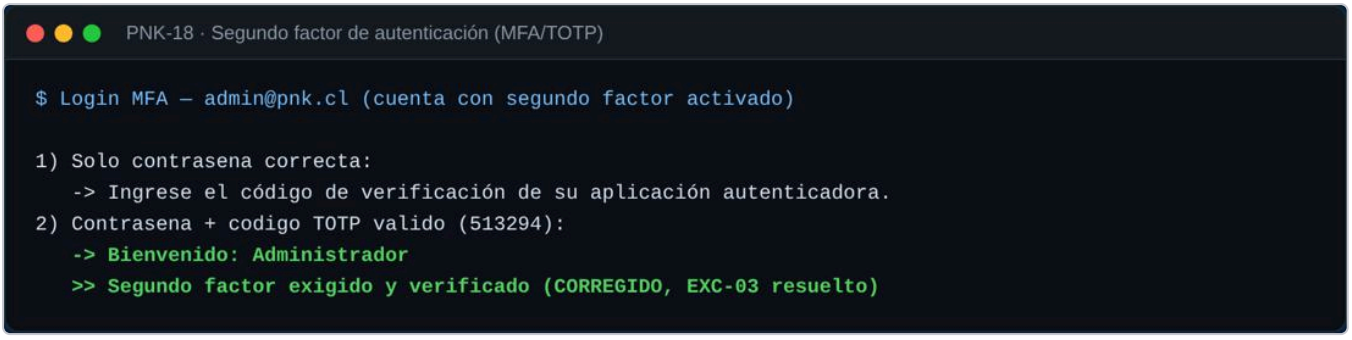
v1 deja el .sql y /vendors/ accesibles; v2 los bloquea con .htaccess

Anexo B · Mejoras implementadas (pendientes resueltos)

Los siguientes controles no eran fallas de la v1, sino requisitos que habían quedado como pendientes. En esta versión se implementaron y se demostraron en el laboratorio aislado.

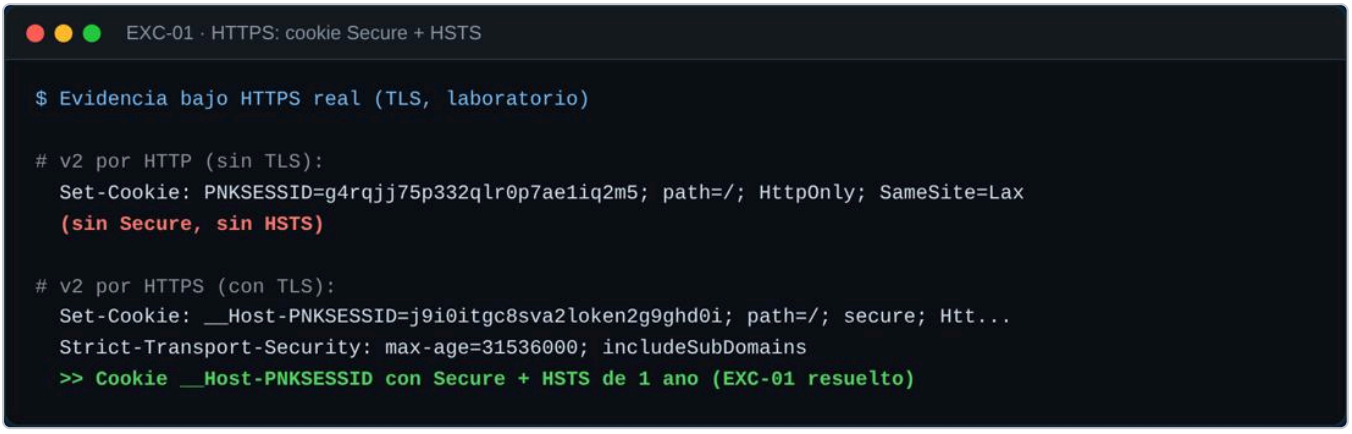
EXC-03 · Autenticación multifactor (MFA / TOTP)

Se agregó un segundo factor opcional por usuario, basado en TOTP (RFC 6238), sin librerías externas. Con la contraseña correcta pero sin código no se autentica; con la contraseña y el código de 6 dígitos de la app autenticadora, sí. Se activa con `herramientas/activar_mfa.php` y está cubierto por las pruebas T25-T27.



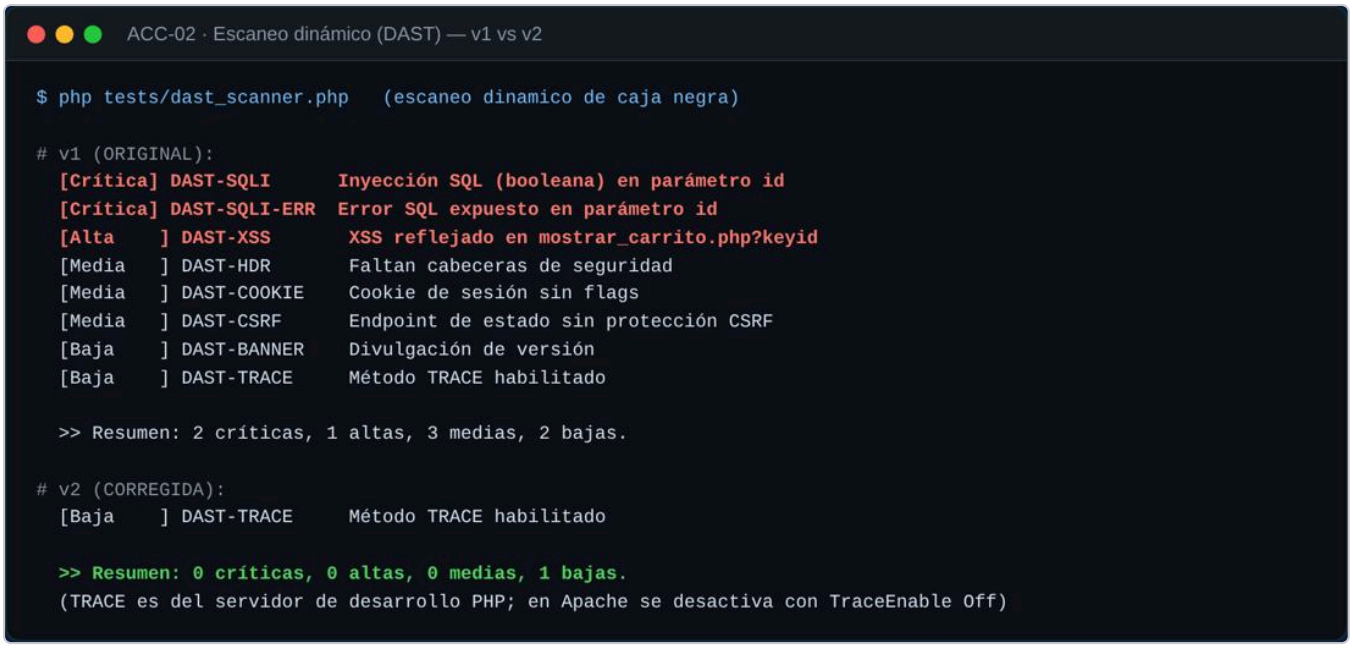
EXC-01 · HTTPS con cookie Secure y HSTS

El código emite la cookie `__Host-PNKSESSID` con `Secure` y la cabecera HSTS cuando el sitio va por TLS (directo o detrás de un proxy de confianza con `TRUST_PROXY`). Se demostró con un certificado de prueba en el laboratorio. Para producción se incluye `config/apache-vhost-ssl.conf` y `herramientas/generar_cert_dev.sh`; sólo falta el certificado del dominio real (certbot).



ACC-02 · Escaneo dinámico (DAST)

Se ejecutó un escáner dinámico de caja negra (pruebas activas no destructivas: SQLi, XSS, cabeceras, cookies, CSRF, métodos HTTP, archivos sensibles y errores) contra la v1 y la v2 en el laboratorio. La v1 arrojó 2 hallazgos críticos, 1 alto, 3 medios y 2 bajos; la v2 quedó en **0 críticos, 0 altos, 0 medios** y 1 bajo (el método TRACE, que pertenece al servidor de desarrollo de PHP y en Apache se desactiva con `TraceEnable Off`). Es un escáner propio porque el entorno no permitió instalar OWASP ZAP; en QA conviene repetirlo con ZAP sobre el ambiente desplegado.



ACC-05 · Pipeline de integración continua

Se agregó `.github/workflows/seguridad.yml`, que en cada cambio corre el lint de PHP, el SAST por patrones, un escaneo de secretos y las 27 pruebas de seguridad, y publica la evidencia como artefacto.

Las capturas de los 17 hallazgos están también en `docs/evidencia_pentest/` (PNG a resolución completa). PNK-01, 05, 09 y 12 se demuestran en el navegador; el resto con paneles de base de datos, código o respuesta HTTP, porque no tienen una representación visual en pantalla.